

Kalkulator ryzyka AI Act

Narzędzie klasyfikujące systemy sztucznej inteligencji pod kątem wymogów Rozporządzenia (UE) 2024/1689 w sposób deterministyczny, z groundingiem LLM na korpusie prawnym EUR-Lex.

AI ACT

Przedmiot	Etyka w sztucznej inteligencji
Uczelnia	Wyższa Szkoła Bankowa · rok akademicki 2025/2026
Autor prototypu	Tomasz Rosik
Autor raportu	Michał Mikołajko
Forma	Raport pisemny + prototyp (Docker Compose)
Repozytorium	github.com/Thomas-RC/ai-act-calculator
Data	18 kwietnia 2026

1. Problem etyczny

1.1. Opis problemu

Wraz z wejściem w życie Rozporządzenia (UE) 2024/1689 — AI Act — 1 sierpnia 2024 r. powstała regulacyjna przestrzeń, w której każdy system sztucznej inteligencji wprowadzany na rynek Unii Europejskiej musi być zaklasyfikowany do jednej z czterech kategorii ryzyka: **niedopuszczalnego** (Art. 5), **wysokiego** (Art. 6 w powiązaniu z Załącznikami I i III), **ograniczonego** (Art. 50 — obowiązki transparentności) lub **minimalnego**. Z każdą kategorią związany jest zupełnie inny zestaw obowiązków dostawcy i deployera — od całkowitego zakazu wprowadzania do obrotu, przez obowiązkowy system zarządzania ryzykiem, dokumentację techniczną, oznaczenie CE, aż po zwykłe poinformowanie użytkownika, że rozmawia z AI.

Empiryczna obserwacja rynku: dostawcy systemów AI — zwłaszcza startupy technologiczne, działy IT w średnich firmach i podmioty publiczne — rzadko potrafią samodzielnie wskazać, do której kategorii należy ich produkt. Przyczyny są kumulatywne: tekst rozporządzenia liczy ponad 140 artykułów i 13 załączników; terminologia jest wysoce specjalistyczna (podmiot stosujący, system wysokiego ryzyka w rozumieniu art. 6 ust. 2); nie istnieje urząd, który ex ante potwierdza klasyfikację — odpowiedzialność spoczywa na samym podmiocie. Skutkiem jest luka kompetencyjna, którą obecnie wypełnia kosztowna usługa kancelarii prawnych (stawki godzinowe 500-1500 zł) albo — częściej — jej brak i milcząca nadzieja, że wdrożenie nie przyciągnie uwagi organu nadzoru.

1.2. Dlaczego to problem etyczny, a nie tylko prawny

AI Act jest instrumentem prawnym, ale jego ratio legis jest etyczne. Preambuła rozporządzenia odwołuje się wprost do Karty Praw Podstawowych UE — **godności** (Art. 1 KPP), **ochrony życia prywatnego** (Art. 7-8), **niedyskryminacji** (Art. 21), **prawa do skutecznego środka prawnego** (Art. 47). Niewłaściwa klasyfikacja systemu AI nie jest więc tylko błędem compliance — jest potencjalnym naruszeniem praw podstawowych osób, na które ten system oddziałuje:

- **Autonomia** podmiotu danych (RODO Art. 22 + AI Act Art. 14) — prawo do niepoddania się decyzji opartej wyłącznie na przetwarzaniu automatycznym. Narzędzie zaklasyfikowane błędnie jako minimalne omija obowiązek nadzoru człowieka.
- **Sprawiedliwość i niedyskryminacja** (Art. 10 AI Act) — obowiązek jakości danych treningowych. Klasyfikacja jako minimalne usuwa wymóg audytu biasu.
- **Godność** w kontekście Art. 5 AI Act — zakaz rozpoznawania emocji w pracy i szkole chroni relację pracownik-pracodawca przed biometrycznym nadzorem. Brak klasyfikacji jako niedopuszczalne oznacza milczące przyzwolenie.
- **Przejrzystość** (Art. 13, Art. 50 AI Act) — użytkownik ma prawo wiedzieć, że wchodzi w interakcję z AI. Pominięcie Art. 50 to naruszenie autonomii informacyjnej.

1.3. Kogo dotyczy problem

Interesariusz	Rodzaj dotknięcia
---------------	-------------------

Obywatel / konsument / pacjent	Przedmiot decyzji AI — pośrednie, ale najpoważniejsze. Skutki: odmowa kredytu, błędna diagnoza, nieuzasadniona kontrola graniczna, stroniczne decyzje rekrutacyjne.
Dostawca systemu AI (producent)	Bezpośredni adresat obowiązków Art. 16. Ryzyko finansowe (kary Art. 99), reputacyjne, odpowiedzialność produktowa.
Deployer (podmiot wdrażający)	Adresat obowiązków Art. 26-27. Odpowiedzialność za kontekst wdrożenia i ocenę skutków dla praw podstawowych (FRIA — Art. 27).
Organ notyfikujący / nadzoru (KE, KNF, UODO, Prezes UODO)	Egzekucja rozporządzenia. Brak pre-klasyfikacji tworzy asymetrię informacyjną — regulator dowiadyuje się post factum, zwykle po incydencie.
Wymiar sprawiedliwości	Rozstrzyganie sporów. Brak udokumentowanej klasyfikacji utrudnia dowodzenie należytej staranności dostawcy.
Społeczeństwo (makro)	Erozja zaufania do technologii AI — każdy głośny incydent (np. błędna decyzja kredytowa w mediach) pogarsza klimat dla całej branży.

1.4. Konsekwencje ignorowania problemu

Wymiar prawny (Art. 99 AI Act).

- Praktyki zakazane (Art. 5): do **35 mln EUR lub 7% światowego obrotu** — wyższa wartość.
- Niespełnienie obowiązków dla systemów wysokiego ryzyka: do **15 mln EUR lub 3%**.
- Podanie nieprawdziwych informacji organowi: do **7,5 mln EUR lub 1%**.

Obok wymiaru prawnego istnieją trudniej kwantyfikowalne, ale dotkliwe konsekwencje: **reputacyjne** — utrata klientów po incydencie medialnym; **operacyjne** — nakaz wycofania systemu z rynku (Art. 82); **społeczne** — każdy precedensowy wyrok zaostrza praktykę interpretacyjną, co utrudnia wdrożenie nawet legalnych, ale źle udokumentowanych systemów; **indywidualne** — dotknięte osoby ponoszą szkody trudne do naprawienia (stygmatyzacja, utrata dostępu do usług, dyskryminacja).

Problem etyczny, który adresuje Kalkulator ryzyka AI Act, można sformułować tak: jak, przy ograniczonych zasobach kompetencyjnych i czasowych po stronie dostawcy, umożliwić pierwszą rzetelną autoklasyfikację systemu AI, nie zastępując audytu prawnego, ale zapewniając, że nikt nie wdroży systemu w nieświadomości ram prawnieto-etycznych?

2. Użytkownik narzędzia

2.1. Kto z niego korzysta

Narzędzie jest adresowane do **dostawcy** lub **deployera** systemu AI w rozumieniu art. 3 pkt 3 i 4 AI Act. W modelu ankietowym użytkownik wybiera rolę (dostawca / deployer / obie jednocześnie), co wpływa na listę obowiązków w wyniku — odpowiednio art. 16 (dostawca) albo art. 26-27 (deployer), albo sumę.

2.2. Konteksty użycia

Persona	Kontekst organizacyjny	Moment w cyklu życia systemu AI
CTO startupu pre-seed	2-5 osób, brak działu compliance, ograniczony budżet	Walidacja pomysłu przed pozyskaniem pierwszego klienta
VP Engineering w scale-upie	50-200 osób, runda serii B	Due diligence przed rozmową z inwestorem lub klientem enterprise
Compliance Officer w banku	Duża instytucja regulowana (KNF)	Pre-analiza przed zgłoszeniem do rejestru systemów wysokiego ryzyka (Art. 71)
Kierownik projektu w JST	Urząd miasta, organ publiczny — Art. 27 wymusza FRIA	Przed podpisaniem umowy z dostawcą zewnętrznym
Student / badacz	Uczelnia, praca magisterska, projekt badawczy	Edukacja, poznanie struktury obowiązków AI Act

2.3. Co użytkownik chce osiągnąć

Cele użytkownika wykraczają poza samą „klasyfikację” — narzędzie musi wspierać konkretne działania po jego uruchomieniu:

- **Szybka pre-kwalifikacja** — odpowiedź na pytanie „czy w ogóle mam problem?” w ciągu kilku minut, nie tygodni.
- **Mapa obowiązków do zaplanowania** — lista pozycji, które można przekuć na backlog techniczny (zarządzanie ryzykiem, dokumentacja, nadzór człowieka).
- **Dokument do zarządu / rady nadzorczej** — raport PDF z podstawą prawną i proweniencją, jako załącznik do wniosku budżetowego lub uchwały.
- **Grounding do dalszej rozmowy z prawnikiem** — użytkownik przychodzi do kancelarii z raportem, zamiast z pustym pytaniem „czy to wysokie ryzyko?”. Oszczędza to 2-4 godziny pracy prawniczej.
- **Świadomość wątpliwości interpretacyjnych** — narzędzie wskazuje miejsca, w których klasyfikacja jest niejednoznaczna (np. art. 6 ust. 3 — wyłączenie z kategorii wysokiego ryzyka).

Kluczowy warunek brzegowy: narzędzie nigdy nie pretenduje do zastąpienia pełnego audytu prawnego. Komunikuje to wprost w interfejsie, w każdej odpowiedzi API i w stopce PDF. Jego wartość polega na tym, że obniża próg wejścia w problematykę AI Act, zwiększając liczbę dostawców, którzy w ogóle świadomie do niej podchodzą.

3. Opis narzędzia — schemat działania

Aplikacja zrealizowana jest jako dwuwarstwowa architektura webowa uruchamiana przez `docker compose up`. Dwa serwisy: `web` (nginx + statyczny frontend) oraz `api` (FastAPI + klasyfikator + Vertex AI). Komunikacja odbywa się przez proxy pass na ścieżce `/api/*`.

3.1. Schemat wejście → logika → wyjście

Etap	Realizacja
WEJŚCIE (Input)	Formularz 10-pytaniowy w 4 sekcjach: A Identyfikacja (opis systemu, cel) · B Filtr Art. 5 (8 zakazanych praktyk jako checkboxy) · C Zakres i kontekst (sektor Zał. III, typ użytkownika, autonomia decyzji, typy danych) · D Elementy

dodatkowe (Zał. I CE, Art. 50, rola dostawca/deployer). Dane serializowane do obiektu `Ankieta` (Pydantic).

LOGIKA (AI)	Dwuwarstwowe przetwarzanie. (1) Deterministyczny klasyfikator w Pythonie stosuje kaskadę reguł: Art. 5 → Zał. I + CE → Zał. III → Art. 50 → fallback. Pierwszy match zwraca kategorię + listę referencji prawnych. (2) Jeśli kategoria ≠ NIEDOPUSZCZALNY, moduł <code>legal.py</code> wyciąga z korpusu pełne teksty właściwych artykułów EUR-Lex i buduje prompt (~10-12k tokenów). Gemini 2.5 Flash w Vertex AI (region europe-west9, Paryż) zwraca ustrukturyzowany JSON z uzasadnieniem, obowiązkami dostawcy i deployera, wątpliwościami interpretacyjnymi i rekomendacjami.
WYJŚCIE (Output)	Trzy elementy równolegle: (1) kategoria — kolorowy badge: czerwony (NIEDOPUSZCZALNY), pomarańczowy (WYSOKIE), żółty (OGRANICZONE), zielony (MINIMALNE); (2) treść merytoryczna — historia decyzji klasyfikatora, uzasadnienie LLM, checklisty obowiązków dostawcy i deployera z podstawą prawną (każdy obowiązek oznaczony <code>ai_act:art_X</code>), wątpliwości, rekomendacje; (3) raport PDF — generowany on-demand przez WeasyPrint z danymi proveniencji (CELEX + data pobrania + sha256 każdego aktu).

3.2. Stos technologiczny

Warstwa	Technologia
Frontend	HTML + TailwindCSS + AlpineJS 3.14 (serwowane przez nginx 1.27-alpine)
Backend	Python 3.12 + FastAPI 0.115 + Pydantic v2 + Uvicorn
Klasyfikator	Reguły kaskadowe w Pythonie (moduł <code>classifier.py</code>)
LLM	Google Vertex AI · Gemini 2.5 Flash · region europe-west9 (Paryż)
Korpus	XHTML z EUR-Lex: AI Act (CELEX 32024R1689, 126 art.), RODO (32016R0679, 99 art.), Karta Praw Podstawowych UE (12012P/TXT, 54 art.). Razem 279 artykułów. Parser lxml + XPath.
PDF	WeasyPrint 63 + Jinja2 3.1 (render HTML → PDF przez Pango+Cairo)
Orkiestracja	Docker Compose v2 (2 serwisy, healthchecks, wolumeny ro/rw)
Testy	pytest — 30 testów (6 EOG, 10 korpus, 14 klasyfikator)

3.3. Przepływ requestu (pełny cykl)

- Użytkownik wypełnia formularz i klika „Klasyfikuj system”. AlpineJS wysła `POST /api/classify` z JSON-em.
- nginx proxy przekazuje żądanie do kontenera `api`; FastAPI waliduje body modelem Pydantic `Ankieta`.
- `classifier.classify()` przechodzi kaskadę reguł i zwraca `WynikKlasyfikacji` (kategoria, legal_basis, powiazane_artykuly, short_circuit).
- Jeśli `short_circuit=True` (kategoria NIEDOPUSZCZALNY), odpowiedź jest zwracana natychmiast bez wywołania LLM.
- W przeciwnym razie: `corpus.build_prompt_corpus(refs)` buduje blok KORPUSU z tekstami właściwych artykułów. `prompts.build_user_prompt()` składa prompt wraz z decyzją klasyfikatora.

6. `VertexClient.generate_structured()` wywołuje Gemini z `response_mime_type='application/json'` i `response_schema`. Model zwraca JSON, który jest walidowany do `WynikAnalizaLLM`.
7. Merge: `OdpowiedzKlasyfikacji` zawiera kategorię + `wynik_reguly` + `wynik_llm` + `korpus_meta` (proweniencja). JSON wraca do frontendu.
8. AlpineJS renderuje wynik w widoku `step='result'`. Kliknięcie „Pobierz PDF” wysyła `POST /api/report`; WeasyPrint renderuje HTML szablonu przez Jinja2 i zwraca binarny PDF.



Sklasyfikuj swój system AI

Odpowiedz na 10 pytań. Otrzymasz kategorię ryzyka wg AI Act, listę obowiązków prawnych i raport PDF. Klasyfikacja jest **doradcza**, nie zastępuje porady prawnej.

A · IDENTYFIKACJA SYSTEMU

Krótki opis systemu AI *

Np. system do automatycznej analizy wniosków o refundację leków w NFZ...

Główny cel systemu *

Np. wstępna selekcja wniosków + rekomendacja decyzji

B · FILTR ART. 5 — ZAKAZANE PRAKTYKI

Czy system realizuje którekolwiek z poniższych?

- ☐ **Manipulacja podprogowa**
Techniki niebędące przedmiotem świadomości — Art. 5 ust. 1 lit. a.
- ☐ **Wykorzystanie wrażliwości osób**
Ze względu na wiek, niepełnosprawność, sytuację — lit. b.
- ☐ **Social scoring przez władzę publiczną**
Ocena zachowań społecznych — lit. c.
- ☐ **Predykcja popełnienia przestępstwa**
Na bazie cech osobowych — lit. d.
- ☐ **Scraping twarzy z internetu/CCTV**
Rozbudowa bazy rozpoznawania twarzy — lit. e.
- ☐ **Rozpoznawanie emocji w pracy/edukacji**
Lit. f.
- ☐ **Kategoryzacja biometryczna (chronione cechy)**
Rasa, poglądy polityczne, religia — lit. g.
- ☐ **Biometria czasu rzeczywistego w przestrzeniach publicznych**
Lit. h.

C · ZAKRES I KONTEKST

Sektor wdrożenia (Zař. III AI Act) *

— żaden z poniższych —

Typ użytkownika końcowego *

Np. pacjent, pracownik, obywatel

Stopień autonomii decyzji *

Doradczy (człowiek decyduje)

Typy danych wejściowych

Ogólne

Biometryczne

Zdrowotne

Behawioralne

Lokalizacyjne

D · ELEMENTY DODATKOWE

- ☐ **System jest komponentem produktu z Zař. I AI Act (CE)**
Np. wyrób medyczny, zabawka, maszyna, motoryzacja — objęty unijnym prawem harmonizacyjnym.
- ☐ **System generuje treści lub wchodzi w interakcję z człowiekiem (Art. 50)**
Np. chatbot, generator obrazów, synteza mowy, deepfake.

Rola użytkownika *

Dostawca

Deployer

Obie

Wyczyść

Klasyfikuj system →

Rys. 1. Widok wejściowy — formularz ankietowy z 10 pytaniami pogrupowanymi w 4 sekcjach tematycznych. Badge „EOG-only” w nagłówku sygnalizuje rezydencję danych.

4. Uzasadnienie techniczne

4.1. Wybór modelu LLM

Kluczowa decyzja techniczna dotyczyła wyboru modelu LLM. Rozważono cztery ścieżki:

Opcja	Zalety	Wada dyskwalifikująca
Gemini 2.5 Flash (Vertex AI, europe-west9)	Natywny region w EOG (Paryż); JSON mode; kontekst 1M tokenów pomieści cały korpus AI Act; koszt ~\$0,075/1M tokenów input	—
GPT-4o (Azure OpenAI)	Jakość generacji, dojrzały ekosystem	Europejskie regiony (Sweden Central, West Europe) stosują content filtering w USA; częściowy transfer prompta poza EOG
Claude 3.5 Sonnet (Anthropic bezpośrednio / AWS Bedrock)	Bardzo wysoka jakość w zadaniach prawnych	Brak regionu EOG dla Bedrocka w 04.2026 (najbliższy Paris dopiero planowany); Anthropic API bez kontroli residencji danych
Własny fine-tune Llama 3 na korpusie UE	Pełna suwerenność, brak zależności od big tech	Koszt datasetu i treningu nieuzasadniony dla MVP (kilkadziesiąt tys. zł); brak kompetencji domenowych w zespole

Wybór: Gemini 2.5 Flash w europe-west9. Uzasadnienie — rezydencja danych była wymogiem etycznym nienegocjowalnym (patrz rozdz. 5). Jakość Flash w testach porównawczych z Pro jest niższa o ~5-8% na benchmarkach ogólnych, ale w zadaniu z pełnym groundingiem (prompt zawiera cytaty dosłowne) model flash okazał się wystarczający; zero halucynacji w dwóch niezależnie zweryfikowanych odpowiedziach. Dodatkowo Flash jest ~10× tańszy od Pro, co ma znaczenie przy scenariuszu produkcyjnym z setkami requestów dziennie.

4.2. Wybór regionu — europe-west9 (Paryż)

Alternatywy w EOG: europe-west1 (Belgia), europe-west3 (Frankfurt), europe-west4 (Holandia). Wszystkie spełniają wymóg EOG. Paryż wybrany z dwóch powodów: (a) **formalny** — Francja ratyfikowała protokół dodatkowy do Konwencji 108+ Rady Europy, co daje dodatkowe zabezpieczenie przetwarzania danych osobowych; (b) **praktyczny** — najniższa latencja z WSB (~25-30 ms) w testach pingiem. Wszystkie regiony EOG zapisane w `config.py` jako zbiór zamknięty; walidacja startowa blokuje aplikację, jeśli ktoś podejmie próbę zmiany na region amerykański.

4.3. Wybór architektury backendu

Decyzja	Alternatywa	Uzasadnienie
FastAPI	Django REST Framework, Flask	Async natywnie, OpenAPI generowane automatycznie, walidacja Pydantic out-of-box, szybki start (brak ORM)

Pydantic v2	dataclasses, attrs	Walidacja runtime, coercion, schemat JSON, integracja z FastAPI
Reguły w Pythonie	DSL (np. Drools), silnik reguł	10 reguł nie uzasadnia infrastruktury; Python jest czytelny dla recenzenta prawnego
lxml + XPath	BeautifulSoup, html.parser	EUR-Lex XHTML używa semantycznych klas (oj-ti-art); XPath daje czytelny selector path
WeasyPrint	Puppeteer, wkhtmltopdf, ReportLab	Czyste Python, brak zależności od przeglądarki; CSS @page dla paginacji; dobra obsługa polskich znaków

4.4. Wybór frontendu

Rozważono React/Next.js, Vue 3, oraz podejście „brak frameworka”. Wybrano **AlpineJS + TailwindCSS przez CDN** — dokładnie bo nie jest to SPA w sensie ekosystemu Node.js. Aplikacja nie wymaga routingu ani state managementu; cały stan mieści się w jednym komponencie Alpine (~170 linii JS). Brak pipeline'u build usuwa cały obszar ryzyka (node_modules, vulnerabilities, lockfile). Tailwind przez CDN w wersji Play daje identyczne API jak PostCSS bez kroku kompilacji. Konsekwencja dla MVP: czas wdrożenia skrócony, ale w wersji produkcyjnej należałoby przejść na Tailwind CLI z sparsowanym CSS-em (Tailwind w trybie CDN ostrzega o produkcji w konsoli).

4.5. Ograniczenia wybranego rozwiązania

- **Probabilizm LLM.** Mimo niskiej temperatury (0,1) Gemini nie jest w pełni reprodukowalny; dwa identyczne requesty mogą zwrócić subtelnie różne redakcje obowiązków. Minimalizujemy przez structured output (JSON schema) — struktura jest deterministyczna, treść nie.
- **Jedna wersja językowa korpusu.** Korpus pobierany jest w języku polskim. Transgraniczny dostawca obsługujący klienta niemieckiego powinien mieć odpowiedź w kontekście niemieckiej wersji AI Act. Rozszerzenie wymaga pobrania i parsowania pięciu wersji językowych.
- **Ankieta 10-pytaniowa to redukcja.** Realny system AI ma setki aspektów relewantnych dla klasyfikacji — ankieta to świadoma heurystyka. Ryzyko: system klasyfikowany błędnie, bo pytanie o kluczową cechę zostało pominięte.
- **Brak audytu prawniczego.** Klasyfikator napisał programista. Mimo 14 testów jednostkowych pokrywających wszystkie ścieżki, nie ma potwierdzenia kancelarii prawnej, że interpretacja Art. 6, Zał. III i Art. 50 jest poprawna.
- **Brak obsługi GPAI.** Modele ogólnego przeznaczenia (Art. 51-56) nie są pokryte — to osobna ścieżka klasyfikacji wymagająca dodatkowych 5-7 pytań.

5. Analiza etyczna

5.1. Decyzje, które czynią narzędzie etyczne

5.1.1. Rezydencja danych — wyłącznie EOG

Vertex AI skonfigurowany w regionie `europa-west9` (Paryż). Dane ankietowe i treść promptów nie opuszczają Europejskiego Obszaru Gospodarczego. W `config.py` istnieje bezwarunkowa walidacja startowa (`REGIONY_EOG` — zbiór 10 regionów); próba uruchomienia w `us-central1` rzuca wyjątek i blokuje aplikację. Uzasadnienie etyczne:

narzędzie doradza w materii prawa UE — ekstraterytorialny transfer danych użytkowników do USA stworzyłby sprzeczność normatywną z RODO Art. 44-49 i odebrałby narzędziu wiarygodność.

5.1.2. Rozdział „reguły twarde” od „redakcji LLM”

Klasyfikacja **nigdy** nie jest decyzją LLM — to deterministyczna kaskada reguł. LLM redaguje wyłącznie skutki: uzasadnienie, listę obowiązków, wątpliwości. Pola `wynik_reguły` i `wynik_llm` są rozdzielone i etykietowane w UI. Użytkownik widzi, która część wyniku pochodzi od prawa, a która od modelu statystycznego.

5.1.3. Grounding na korpusie EUR-Lex z proveniencją sha256

Prompt systemowy zawiera blok KORPUSU — dosłowne teksty artykułów pobrane z `eur-lex.europa.eu` z metadanymi CELEX, ELI, data pobrania, sha256. Prompt wprost zakazuje cytowania spoza KORPUSU. Stopka PDF powtarza te metadane — dokument jest falsyfikowalny: czytelnik może obliczyć sha256 oryginalnego pliku EUR-Lex i zestawzić z treścią raportu.

Obserwacja empiryczna. W teście scenariusza RefundAI (NFZ) Gemini zacytował Zał. III pkt 5 lit. a) niemal 1:1 z oryginalnego tekstu dyrektywy; trafnie wskazał możliwość wyłączenia z kategorii wysokiego ryzyka na podstawie Art. 6 ust. 3 — przesłankę, której nie było w bezpośrednich referencjach klasyfikatora. Zero halucynacji w dwóch niezależnie zweryfikowanych odpowiedziach.

5.1.4. Short-circuit dla Art. 5

Dla systemów realizujących praktyki zakazane LLM **nie jest wywoływany**. Art. 5 to twardy zakaz normatywny, nie materia interpretacyjna. Usunięcie LLM eliminuje ryzyko, że halucynacja złagodzi kategoriyczny zakaz prawny.

5.1.5. Jawny status doradczy

Każda odpowiedź zawiera pole `disclaimer` powielone w stopce PDF. Celem jest jednoznaczne zarządzanie oczekiwaniami — narzędzie to pierwsza iteracja w procesie due diligence, nie substytut adwokata.

5.2. Ryzyka samego narzędzia — czy ono może powodować błędy lub nadużycia?

Meta-refleksja: narzędzie zaprojektowane do wykrywania ryzyk etycznych innych systemów AI samo jest systemem AI i samo generuje ryzyka. Zidentyfikowano sześć głównych:

Ryzyko	Mechanizm minimalizacji
Automation bias — użytkownik przyjmuje wynik jako ostateczny i rezygnuje z konsultacji prawniczej	Ekspozowany disclaimer w UI, PDF i w polu odpowiedzi API; sekcja „wątpliwości interpretacyjne” wymuszona jako pole obligatoryjne w schemacie LLM
Iluzja compliance („mamy certyfikat od AI, więc jesteśmy OK”)	Narzędzie nie wydaje „certyfikatu” — raport PDF nazwany explicite raportem wstępnym; stopka wskazuje, że nie jest to dokument zgodności
Bias modelu Gemini — trenowany głównie na angielskich korpusach prawnych, polska terminologia może być słabiej pokryta	Grounding na pełnych tekstach EUR-Lex po polsku; prompt systemowy wymusza cytowanie z korpusu; temperatura 0,1

Nadużycia marketingowe — reselling usługi „AI Act audit” przez podmioty bez kompetencji prawniczych	Licencja i README wprost ograniczają zastosowanie do celów edukacyjnych i pre-kwalifikacyjnych; brak API komercyjnego
Rozbieżność korpus ↔ judykatura — prawo to nie tylko tekst, to też orzeczenia (TSUE, krajowe sądy)	Sekcja „wątpliwości” sygnalizuje, kiedy literalny tekst jest niejednoznaczny; rozdz. 7 raportu wskazuje na konieczność konsultacji w takich przypadkach
Wykluczenie językowe — obecnie tylko polska wersja; dostawca zagraniczny mógłby otrzymać niespójną klasyfikację	Limitacja zadeklarowana w nagłówku UI i w dokumentacji; na roadmapie: wsparcie wersji DE/FR/EN

5.3. Zasady przewodnie (framework HLEG)

Narzędzie zostało świadomie zaprojektowane w zgodzie z siedmioma wymogami Trustworthy AI High-Level Expert Group on AI (2019), z wyraźnym wskazaniem, gdzie które zostało adresowane:

Wymóg HLEG	Realizacja w projekcie
Human agency and oversight	Klasyfikacja oparta na regułach (nie LLM); jawny disclaimer; sekcja wątpliwości wymusza świadome dopytanie
Technical robustness and safety	30 testów pytest; healthchecks; walidacja wejścia Pydantic
Privacy and data governance	EOG-only; brak zapisu promptów po stronie aplikacji; logowanie tylko metryk (tokens, kategoria)
Transparency	Rozdział reguły/LLM w UI; proveniencja CELEX + sha256; pełna widoczność decyzji klasyfikatora („historia reguł”)
Diversity, non-discrimination, fairness	Klasyfikator nie używa danych osobowych; ankieta pyta o system, nie o użytkownika; korpus to publiczny akt prawny
Societal and environmental well-being	Gemini Flash (niższe zużycie energii niż Pro); brak niepotrzebnych wywołań LLM (short-circuit dla Art. 5)
Accountability	Kod w publicznym repo GitHub; licencja; raport PDF ma CELEX i sha256 — dokumentacja decyzji

6. Odniesienie do AI Act — klasyfikacja samego narzędzia

Kalkulator ryzyka AI Act jest systemem sztucznej inteligencji w rozumieniu art. 3 pkt 1 AI Act — wykorzystuje duży model językowy do generowania tekstu wpływającego na decyzje podmiotów wdrażających AI. Podlega więc klasyfikacji na tych samych zasadach, na których klasyfikuje inne systemy. Zastosujemy do niego własną kaskadę:

6.1. Art. 5 — praktyki zakazane

Narzędzie nie wykonuje manipulacji podprogowej, nie exploituje wrażliwości, nie prowadzi social scoringu, nie kategoryzuje biometrycznie, nie rozpoznaje emocji, nie prowadzi biometrii w czasie rzeczywistym. **Nie ma praktyki zakazanej.**

6.2. Art. 6 ust. 1 + Załącznik I

Narzędzie nie jest komponentem produktu objętego oceną zgodności (CE) w unijnych aktach harmonizacyjnych. **Nie wpada w Załącznik I.**

6.3. Art. 6 ust. 2 + Załącznik III

Przegląd ośmiu sektorów Zał. III:

- **Pkt 1 — biometria.** Narzędzie nie przetwarza danych biometrycznych. Nie.
- **Pkt 2 — infrastruktura krytyczna.** Nie zarządza energetyką, transportem ani ruchem drogowym. Nie.
- **Pkt 3 — edukacja.** Nie ocenia uczniów, nie przydziela do szkół, nie wykrywa oszustw egzaminacyjnych. Nawet przy zastosowaniu jako pomoc dydaktyczna — nie podejmuje decyzji o statusie edukacyjnym użytkownika. Nie.
- **Pkt 4 — zatrudnienie.** Nie wspiera decyzji rekrutacyjnych ani zarządzania pracownikami. Nie.
- **Pkt 5 — usługi publiczne i prywatne.** Nie decyduje o dostępie do świadczeń, zdolności kredytowej, ryzyku ubezpieczeniowym, klasyfikacji zgłoszeń alarmowych. Nie.
- **Pkt 6 — ściganie.** Nie jest wykorzystywane przez organy ścigania. Nie.
- **Pkt 7 — migracja, azyl, kontrola graniczna.** Nie. Nie.
- **Pkt 8 — wymiar sprawiedliwości i procesy demokratyczne.** Narzędzie redaguje obowiązki prawne, ale nie jest wykorzystywane przez sąd lub w jego imieniu do rozstrzygnięcia sprawy, interpretacji prawa lub badania faktów (art. 6 ust. 2 w zw. z Zał. III pkt 8 lit. a). Redakcja obowiązków na potrzeby due diligence nie jest funkcją sądową. Nie.

6.4. Art. 50 — obowiązki transparencji

Narzędzie **wchodzi w interakcję z osobami fizycznymi** (dostawcy, deployerzy) i **generuje tekst** (uzasadnienia, obowiązki, rekomendacje). Dwie przesłanki Art. 50 są spełnione:

- **Art. 50 ust. 1:** dostawca systemu AI przeznaczonego do interakcji z osobami fizycznymi zapewnia, że osoba jest informowana, że wchodzi w interakcję z systemem AI. **Realizacja:** badge „EOG-only” + treść w headerze wskazująca, że to narzędzie AI; disclaimer w każdej odpowiedzi.
- **Art. 50 ust. 2-3:** treści generowane syntetycznie (audio, obraz, wideo, tekst) mają być oznaczone jako takie, jeśli treść stanowi deep fake lub tekst przeznaczony do informowania opinii publicznej. **Nie dotyczy:** nasza generacja to tekst o charakterze eksperckim, adresowany do konkretnego użytkownika ankiety, nie publikowany jako news / deep fake.

Wniosek klasyfikacyjny. Zgodnie z własną kaskadą narzędzia, Kalkulator ryzyka AI Act jest systemem AI **kategorii OGRANICZONEJ** (**OGRANICZONE**) — z obowiązkami transparencji wynikającymi z Art. 50 ust. 1.

6.5. Obowiązki wynikające z klasyfikacji

- **Art. 50 ust. 1 — jasna informacja o naturze AI.** Zrealizowane — nagłówek UI, badge, disclaimer, stopka PDF.
- **Art. 95 — dobrowolne kodeksy postępowania.** Narzędzie nie ma twardego obowiązku, ale rekomendacja etyczna: opublikować Model Card (Mitchell et al. 2019)

opisujący ograniczenia modelu i korpusu. **Kierunek rozwoju** — w roadmapie (rozd. 7).

- **Art. 13 + Art. 10 (dobrowolnie, mimo kategorii OGRANICZONE).** Instrukcja obsługi w README; jakość korpusu zapewniona przez sha256 + proveniencję.

7. Wnioski, weryfikacja i ograniczenia

7.1. Co działa

Prototyp pokryty 30 testami jednostkowymi w pytest : 6 · walidacja rezydencji EOG, 10 · parser XHTML korpusu, 14 · wszystkie ścieżki klasyfikatora (w tym kazus RefundAI z CW2). Weryfikacja end-to-end na trzech scenariuszach:

Scenariusz A · **NIEDOPUSZCZALNY** — rozpoznawanie emocji w pracy

System analizy wyrazu twarzy pracowników call-center w czasie rzeczywistym. Klasyfikator w ~2 ms zwraca kategorię bez wywołania LLM (short_circuit=True), powołując się na Art. 5 ust. 1 lit. f) AI Act.

Kalkulator ryzyka AI Act
Rozporządzenie (UE) 2024/1689

EOG-only Korpus: 2026-04-18

KATEGORIA RYZYKA

NIEDOPUSZCZALNY

Podstawa: ai_act:art_5

Historia decyzji klasyfikatora

1

Art. 5 AI Act — zakazane praktyki

System realizuje praktyki zakazane: rozpoznawanie_emocji

Short-circuit: klasyfikator rozstrzygnął kategorię na poziomie reguł bez wywoływania LLM (system realizuje zakazaną praktykę z Art. 5).

Źródła prawne (wszystkie pobrane bezpośrednio z EUR-Lex):

- Rozporządzenie (UE) 2024/1689 (AI Act) · CELEX 32024R1689 · pobrano 2026-04-18 · sha256 306c2281a3c1...
- Karta Praw Podstawowych Unii Europejskiej · CELEX 12012P/TXT · pobrano 2026-04-18 · sha256 0a1ca5411f02...
- Rozporządzenie (UE) 2016/679 (RODO) · CELEX 32016R0679 · pobrano 2026-04-18 · sha256 38c3d187200b...

Klasyfikacja ma charakter doradczy. Nie zastępuje porady prawnej ani pełnego audytu zgodności.

Rozpocznij od nowa

Pobierz raport PDF

Projekt zaliczeniowy · Etyka w AI · WSB 2025/2026 · Dane nie opuszczają EOG (Vertex AI Paryż).

Rys. 2. Kategoria NIEDOPUSZCZALNY — historia reguł, jawna informacja o short-circuit, proveniencja korpusu.

Scenariusz B · **WYSOKIE** — analiza wniosków refundacyjnych NFZ

Model wspierający decyzje urzędników o refundacji leków. Kaskada: Art. 5 brak → Zał. I brak CE → **Zał. III pkt 5 lit. a)** (usługi publiczne) → WYSOKIE. Gemini otrzymuje prompt z pełnymi tekstami 7 artykułów (~10,7k tokenów) i redaguje 6 obowiązków dostawcy + 1 obowiązek deployera (FRIA · Art. 27), 2 trafne wątpliwości interpretacyjne i 8 rekomendacji.



KATEGORIA RYZYKA

WYSOKIE

Podstawa: ai_act:art_6, ai_act:anx_III



Uzasadnienie

Państwa system AI do automatycznej analizy wniosków refundacyjnych NFZ, rekomendujący decyzje urzędnikowi, został zaklasyfikowany jako system wysokiego ryzyka. Wynika to z art. 6 ust. 2 Rozporządzenia (UE) 2024/1689 (AI Act) w związku z Załącznikiem III pkt 5 lit. a. Systemy AI wykorzystywane przez organy publiczne do oceny kwalifikowalności osób fizycznych do podstawowych świadczeń publicznych, w tym opieki zdrowotnej, są uznawane za wysokiego ryzyka.



Historia decyzji klasyfikatora

- 1 Art. 5 AI Act
Brak zakazanych praktyk.
- 2 Art. 6 ust. 1 + Załącznik I
System nie jest produktem z oceną zgodności.
- 3 Art. 6 ust. 2 + Załącznik III AI Act
Sektor 'usługi_publiczne' ≡ Zał. III pkt 5.



Obowiązki dostawcy

- Ustanowienie, wdrożenie, udokumentowanie i obsługa systemu zarządzania ryzykiem, który jest ciągłym, iteracyjnym procesem obejmującym identyfikację, analizę, oszacowanie, ocenę ryzyka oraz przyjęcie odpowiednich środków zarządzania ryzykiem. (ai_act:art_9)
- Testowanie systemu AI wysokiego ryzyka w celu określenia najodpowiedniejszych środków zarządzania ryzykiem, zapewniając jego działanie zgodne z przeznaczeniem i wymogami, przed wprowadzeniem do obrotu lub oddaniem do użytku. (ai_act:art_9)
- Rozwijanie systemu AI na podstawie zbiorów danych treningowych, walidacyjnych i testowych spełniających kryteria jakości, w tym adekwatności, reprezentatywności, wolności od błędów i kompletności, z uwzględnieniem praktyk zarządzania danymi, takich jak badanie i ograniczanie stronniczości. (ai_act:art_10)
- Sporządzenie i aktualizowanie dokumentacji technicznej przed wprowadzeniem systemu do obrotu lub oddaniem do użytku, aby wykazać zgodność z wymogami AI Act i dostarczyć niezbędnych informacji do oceny zgodności. (ai_act:art_11)
- Projektowanie i rozwijanie systemu AI w sposób zapewniający wystarczającą przejrzystość jego działania, umożliwiającą podmiotom stosującym interpretację wyników i ich właściwe wykorzystanie. (ai_act:art_13)
- Dotarcie do systemu AI instrukcji obsługi w odpowiednim formacie, zawierającej zwięzłe, kompletne, poprawne i jasne informacje, w tym tożsamość dostawcy, cechy, możliwości i ograniczenia systemu, ryzyka, środki nadzoru ze strony człowieka oraz wymagane zasoby. (ai_act:art_13)
- Projektowanie i rozwijanie systemu AI w taki sposób, aby mógł być skutecznie nadzorowany przez osoby fizyczne, z uwzględnieniem odpowiednich narzędzi interfejsu człowiek-maszyna, w celu zapobiegania lub minimalizowania ryzyka. (ai_act:art_14)
- Zapewnienie, aby system AI osiągał odpowiedni poziom dokładności, solidności i cyberbezpieczeństwa oraz działał konsekwentnie pod tymi względami w całym cyklu życia, deklarując poziomy dokładności w instrukcji obsługi. (ai_act:art_15)



Obowiązki deployera

- Przed wdrożeniem systemu AI, jako podmiot publiczny lub podmiot prywatny świadczący usługi publiczne, należy przeprowadzić ocenę skutków dla praw podstawowych (FRIA). Ocena ta powinna obejmować opis procesów, okres i częstotliwość wykorzystania, kategorie osób, na które system może mieć wpływ, ryzyka, środki nadzoru ze strony człowieka oraz środki zaradcze. (ai_act:art_27)
- Po przeprowadzeniu oceny skutków dla praw podstawowych, należy powiadomić organ nadzoru rynku o jej wynikach, przedstawiając wypełniony wzór kwestionariusza. (ai_act:art_27)



Wątpliwości interpretacyjne

- Czy system, który jedynie rekomenduje decyzje urzędnikowi i służy do wstępnej selekcji wniosków, może kwalifikować się do odstępstwa od klasyfikacji wysokiego ryzyka na podstawie art. 6 ust. 3, jeśli nie stwarza znaczącego ryzyka szkody dla zdrowia, bezpieczeństwa lub praw podstawowych osób fizycznych, np. poprzez brak znaczącego wpływu na wynik procesu decyzyjnego?
- W przypadku, gdy dostawca uważa, że system AI, o którym mowa w załączniku III, nie jest systemem wysokiego ryzyka (zgodnie z art. 6 ust. 3), czy dostawca jest świadomy obowiązku udokumentowania swojej oceny przed wprowadzeniem systemu do obrotu lub oddaniem go do użytku, zgodnie z art. 6 ust. 4?

Rys. 3. Kategoria WYSOKIE — uzasadnienie LLM, obowiązki dostawcy/deployera z podstawą prawną, wątpliwości.

Scenariusz C · MINIMALNE — filtr antyspamowy

Standardowy filtr wiadomości e-mail — żadna z reguł kaskady nie trafia, fallback na kategorię MINIMALNE. LLM rekomenduje dobrowolne kodeksy postępowania zgodnie z Art. 95. Brak obowiązków twardych.

7.2. Ograniczenia obecnej wersji

- **Zakres pytań** — 10 pytań nie pokrywa GPAI (Art. 51-56), Art. 72 (monitoring post-market) ani procedur oceny zgodności (Zał. VI-VII).
- **Brak audytu prawniczego** — narzędzie nie przeszło walidacji przez kancelarię specjalizującą się w regulacjach cyfrowych.
- **Probabilizm modelu** — mimo groundingu, LLM pozostaje statystyczny; produkcyjne wdrożenie wymagałoby datasetu ewaluacyjnego.
- **Aktualność korpusu** — fallback to snapshot z 18.04.2026; brak webhooka na zmiany w EUR-Lex.
- **Jedna wersja językowa** — tylko polska; transgraniczne zastosowania niepełne.

7.3. Kierunki rozwoju

- Rozszerzenie o GPAI i obowiązki post-market (Art. 72-73).
- Dataset ewaluacyjny z ~50 anotowanymi kazusami do pomiaru trafności klasyfikacji.
- Model Card w rozumieniu Mitchell et al. (2019) — formalizacja ograniczeń modelu.
- Integracja z rejestrem systemów wysokiego ryzyka (Art. 71) oraz konektor do KNF/UODO dla sektora finansowego.
- Wariant wielojęzyczny: korpus wersji oficjalnych DE/FR/EN.
- Webhook EUR-Lex dla automatycznej aktualizacji korpusu po publikacji aktu zmieniającego.
- Moduł audytowy — log decyzji klasyfikatora z zapisem wejścia, wyjścia i użytego snapshotu korpusu (reprodukowalność dla audytora).

8. Podział pracy

Projekt zrealizowany w dwuosobowym podziale zadań — techniczny prototyp i dokumentacja pisemna jako osobne odpowiedzialności.

Obszar	Autor	Zakres
Architektura systemu	Tomasz Rosik	Dobór stosu (FastAPI / Alpine / Vertex AI), dekompozycja na moduły, docker compose
Klasyfikator deterministyczny	Tomasz Rosik	Kaskada reguł Art. 5 → Zał. I → Zał. III → Art. 50, 14 testów pytest
Backend FastAPI	Tomasz Rosik	Endpointy /classify, /report, /meta, /health; walidacja Pydantic; lifespan + CORS
Integracja Vertex AI	Tomasz Rosik	VertexClient, prompt engineering, response schema JSON, walidacja EOG
Tomasz Rosik		

Korpus prawny + parser		Skrypt pobierania z EUR-Lex, parser lxml + XPath (dwa formaty: oj-ti-art i ti-art legacy), sha256
Frontend + UX	Tomasz Rosik	Formularz 10-pytaniowy w Tailwind + Alpine, widoki result/loading/error, PDF download
Generator PDF	Tomasz Rosik	WeasyPrint + Jinja2, template raportu, kolorowy badge kategorii, stopka proveniencji
Testy jednostkowe	Tomasz Rosik	30 testów pytest (EOG, korpus, klasyfikator), pokrycie wszystkich ścieżek decyzyjnych
Raport pisemny	Michał Mikołajko	Całość dokumentu — struktura 8 rozdziałów, analiza etyczna, klasyfikacja meta (rozdz. 6), literatura, redakcja
Badanie problemu etycznego	Michał Mikołajko	Rozdz. 1 (problem etyczny), rozdz. 2 (użytkownik), rozdz. 5 (analiza etyczna + ryzyka własne narzędzia), mapowanie HLEG
Prezentacja	Wspólnie	Materiały i demo scenariuszy testowych

9. Źródła

Akty prawne (korpus aplikacji)

- Rozporządzenie Parlamentu Europejskiego i Rady (UE) **2024/1689** z dnia 13 czerwca 2024 r. ustanawiające zharmonizowane przepisy dotyczące sztucznej inteligencji oraz zmieniające niektóre akty ustawodawcze Unii (AI Act). CELEX 32024R1689. Dz.Urz. UE L 1689/1.
- Rozporządzenie Parlamentu Europejskiego i Rady (UE) **2016/679** z dnia 27 kwietnia 2016 r. w sprawie ochrony osób fizycznych w związku z przetwarzaniem danych osobowych i w sprawie swobodnego przepływu takich danych (RODO). CELEX 32016R0679. Dz.Urz. UE L 119/1.
- Karta Praw Podstawowych Unii Europejskiej (wersja skonsolidowana). CELEX 12012P/TXT. Dz.Urz. UE C 326/391.

Literatura przedmiotu

- High-Level Expert Group on AI (2019). Ethics Guidelines for Trustworthy AI. European Commission, Bruksela.
- Floridi, L., Cowls, J., Beltrametti, M. et al. (2018). AI4People — An Ethical Framework for a Good AI Society: Opportunities, Risks, Principles, and Recommendations. Minds and Machines 28(4), s. 689-707.
- Veale, M., Zuiderveen Borgesius, F. (2021). Demystifying the Draft EU Artificial Intelligence Act. Computer Law Review International 22(4), s. 97-112.
- Hacker, P., Engel, A., Mauer, M. (2023). Regulating ChatGPT and other Large Generative AI Models. 2023 ACM Conference on Fairness, Accountability, and Transparency (FAccT'23), s. 1112-1123.
- Mitchell, M., Wu, S., Zaldivar, A. et al. (2019). Model Cards for Model Reporting. Proceedings of the Conference on Fairness, Accountability, and Transparency (FAT* '19), s. 220-229.
- Wachter, S., Mittelstadt, B., Russell, C. (2017). Counterfactual Explanations without Opening the Black Box: Automated Decisions and the GDPR. Harvard Journal of Law & Technology 31(2), s. 841-887.
- Jobin, A., Ienca, M., Vayena, E. (2019). The global landscape of AI ethics guidelines. Nature Machine Intelligence 1(9), s. 389-399.